LEXIGRID

Multi-Tenant Administration

Version 5.54.15 | Reviewed 2026-11-11

Shahryar Jahangir, Aniza Inc.

Procedures, examples, verification and operational limits. Complete commissioning on your deployment before serving customer traffic. Sample values are fictional; original keys and data must be preserved.

Contents

Multi-tenant administration **3**

Roles and scope 3

Provision an organization 3

Tenant user creation 3

Entra/AD FS binding 3

Security checks 3

Operational recovery 4

Multi-tenant administration

Roles and scope

A platform administrator may provision a named tenant and initial tenant administrator. A tenant administrator manages supported user operations within its signed-in tenant. A risk contact's owner/watcher/approver/auditor/reviewer label is descriptive and grants no login or API permission.

Tenant names are visible in the unauthenticated organization selector. Their visibility does not grant membership or authorize a tenant switch. Every object/query/import/attachment/report must be checked against the authenticated tenant, with PostgreSQL RLS as an additional enforcement layer.

Provision an organization

1. Sign in as platform administrator and confirm the current tenant/role.

2. Open Administration and enter the new organization name, initial administrator email and a strong initial password through the protected form.

3. Submit once. Creation of the tenant/user is atomic and audited under the actual actor.

4. Verify the tenant in the selector, the initial account role and successful designated test login.

5. Confirm a tenant administrator cannot call the platform provisioning API and cannot view another tenant's ordinary user list.

Duplicate names/accounts produce a conflict rather than a partial organization. Do not reuse a business owner's email as a substitute for a formally authorized administrator.

Tenant user creation

Within Administration, provide normalized email, password and a permitted tenant role. The server uses the caller's tenant rather than accepting arbitrary target tenant IDs. Verify the new account in that tenant's user list, its role, active state and the user-create audit event. Passwords must not appear in responses or audit details.

Use Change access beside a user to set their tenant role or active state. Deactivation blocks sign-in and revokes sessions; reactivation does not restore old tokens. Stale security revisions are rejected. Another administrator must change your account; platform administrator access requires privileged owner administration. The server serializes organization access changes and preserves an active administrator. Owner CLI identity binding and password recovery remain separate privileged operations. User records and historical authorship are retained.

Entra/AD FS binding

Configure federation per the SSO manual. Pre-provision the local account and bind exact issuer/application subject for OIDC or stable NameID for SAML. Both bindings may refer to the same local account. They do not assign a role from directory claims. A signed token containing the same email as another user is not sufficient to authenticate that account.

Security checks

Use two synthetic tenants and separate test users. Verify foreign-tenant GET/import/download denial, role denial and audit attribution. In PostgreSQL, the API must use restricted lexigrid_runtime, not a schema owner. Platform provisioning temporarily scopes new-user creation to the new tenant, then restores the caller context before audit/commit. Ordinary requests do not receive platform-wide object access merely because the actor is platform_admin.

Operational recovery

For a stale/conflicting change, refresh the displayed record and verify current state before retrying. Do not bulk-reset users or tenants to repair an import or SSO issue. Preserve original keys so existing MFA/evidence remain readable.
Cross-tenant reporting is separately scoped feature work and is not provided by the standard tenant report.